

NationalBank Reserve - Red Team Engagement

Checkpoint 5: Executive Pentest Report + Defensive Roadmap

Analyst: Mustafa Musa Ahmed | **Year:** 2026

Classification: CONFIDENTIAL - Authorized Lab Environment

Deliverables: Full pentest report, risk matrix, 90-day roadmap, 5-min briefing

1. Executive Summary

NationalBank Reserve engaged a red team to assess the security posture of its simulated banking infrastructure across 5 phases: scoping and threat modelling (CP1), infrastructure assessment (CP2), web + API assessment (CP3), social engineering + detection evasion (CP4), and this consolidated executive report (CP5).

The assessment identified 22 findings: - **5 CRITICAL** - allow full compromise (RCE, auth bypass, DB credential leak) - **12 HIGH** - data theft, privilege escalation, account takeover - **3 MEDIUM** - defense-in-depth erosion - **2 LOW** - information disclosure / observation

Overall risk rating: CRITICAL.

Full compromise of the simulated environment was achieved in **under 15 minutes** using only public tooling, default credentials, and one phishing email. No advanced tooling or zero-days were required.

Most severe business impact: If applied to production, an attacker could extract all customer records, execute arbitrary code on the web server, bypass authentication to any account, and read internal files via SSRF. Regulatory exposure (PCI-DSS, RBI guidelines) would be immediate and material.

Recommended immediate action: Isolate the affected systems, disable the vulnerable services (FTP, Telnet, unrestricted file upload), rotate all credentials, and execute the 90-day defensive roadmap below.

2. Engagement Scope & Rules

Item	Value
Client	NationalBank Reserve (Mumbai, 5,000 employees)
Scope	External attack surface + simulated internal access

Item	Value
In-scope	DVWA (simulated web), Flask API (simulated), Kali attacker, MailHog, Gophish
Out-of-scope	Real customer data, production networks, physical intrusion, DoS
Authorization	Authorized lab capstone
Timeline	5 checkpoints over 12 weeks

3. Assessment Methodology

Phase	Tooling	Output
Reconnaissance	Nmap 7.98, Nikto 2.6.1, manual OSINT	Ports, services, versions, web paths
Web	Custom Python (requests), DVWA v1.10	OWASP Top 10 findings
API	Custom Python (flask + requests), JWT	API Security Top 10 findings
Social Engineering	Gophish v0.12.1, MailHog	Phishing kill chain evidence
Detection Evasion	msfvenom, custom XOR obfuscator, ClamAV	Signature bypass results
Scoring	CVSS v3.1, MITRE ATT&CK, OWASP	Severity + mapping

4. Risk Matrix

	Low Impact	Medium Impact	High Impact	Critical Impact
High Likelihood		NB-15, NB-16	NB-13, NB-14, NB-18	NB-01, NB-02, NB-03, NB-04, NB-05

	Low Impact	Medium Impact	High Impact	Critical Impact
Medium Likelihood	NB-17	NB-12, NB-22	NB-06, NB-07, NB-08, NB-09, NB-10, NB-11, NB-19, NB-20, NB-21	
Low Likelihood				

5. Findings Summary

Full details in `Unified_Findings_Register.md`. Top 10 by severity:

ID	Finding	CVSS	Severity
NB-01	DB credentials exposed via <code>.bak</code> file	9.8	CRITICAL
NB-02	SQL Injection (web)	9.8	CRITICAL
NB-03	Command Injection / RCE	9.8	CRITICAL
NB-04	API Broken Authentication	9.8	CRITICAL
NB-05	API SQL Injection	9.8	CRITICAL
NB-06	BOLA - cross-user object access	8.6	HIGH
NB-09	SSRF - local file read	8.6	HIGH
NB-18	Unrestricted file upload	8.8	HIGH
NB-07	Excessive data exposure	8.2	HIGH
NB-08	Mass assignment to admin role	8.1	HIGH

6. Attack Chain - How It All Connects

1. **Initial Access (CP4)** - Phishing email (`it-support@nationalbank.com`) bypassed gateway → user clicked → credentials captured (NB-19, NB-20)
2. **Authentication Bypass** - API admin endpoint open (NB-04) OR login SQLi (NB-05)
3. **Lateral Access** - BOLA (NB-06) + excessive data exposure (NB-07) enumerate all users and API keys
4. **Privilege Escalation** - Mass assignment (NB-08) grants admin role

5. **Server Compromise** - SQLi (NB-02) → command injection (NB-03) → RCE as `www-data`
6. **Persistence & Exfil** - SSRF (NB-09) reads `/etc/passwd`; config backup (NB-01) leaks DB credentials
7. **Defense Evasion** - Custom XOR obfuscation (NB-21) defeats signature AV

Time to full compromise: < 15 minutes.

7. 90-Day Defensive Roadmap

Days 0-7 - CONTAIN (Immediate)

#	Action	Owner	Finding
1	Isolate vulnerable hosts from production network	Infra	All
2	Rotate all DB, API, admin credentials + API keys	SecOps	NB-01, 04, 05, 07
3	Delete <code>config.inc.php.bak</code> and any backup files from web root	Web	NB-01
4	Disable FTP, Telnet, unrestricted file upload	Infra	NB-18
5	Block external senders spoofing <code>@nationalbank.com</code> (SPF/DKIM/DMARC)	Email	NB-19
6	Force password reset for all lab accounts + enable MFA	IAM	NB-20
7	Enable WAF rules for SQLi/XSS/SSRF patterns	SecOps	NB-02, 05, 09, 11, 12

Days 8-30 - HARDEN (Short-term)

#	Action	Owner	Finding
8	Patch Apache, PHP, and any outdated libraries	Infra	NB-14
9	Remove directory indexing; disable /config/ public access	Web	NB-13
10	Implement parameterized queries everywhere	Dev	NB-02, 05
11	Add authorization checks to every API endpoint (object + function level)	Dev	NB-04, 05, 06, 08
12	Strip sensitive fields (password, api_key) from API responses	Dev	NB-07
13	Add CSRF tokens to all state-changing forms	Dev	NB-10
14	Sanitize/encode all user input (stored + reflected XSS)	Dev	NB-11, 12
15	Validate + whitelist SSRF allow-list destinations	Dev	NB-09
16	Deploy EDR (replace signature-only AV)	SecOps	NB-21
17	Enable AMSI + script block logging	SecOps	NB-21

#	Action	Owner	Finding
18	Set HttpOnly + Secure + SameSite=Strict on all session cookies	Dev	NB-15
19	Add missing security headers (CSP, HSTS, XCTO, Referrer-Policy)	Web	NB-16
20	Restrict file-upload MIME + extension + scan with AV	Web	NB-18

Days 31-90 - MATURE (Long-term)

#	Action	Owner
21	Roll out phishing-resistant MFA (FIDO2) to all privileged users	IAM
22	Quarterly phishing simulations + monthly awareness training	HR/Sec
23	Application allowlisting on all production servers	Infra
24	Full network segmentation (DMZ / app / DB / mgmt)	Infra
25	Centralized logging + SIEM with behavioural rules	SecOps
26	24/7 SOC monitoring with threat-hunting rotation	SecOps
27	Formal patch management (30-day cycle for Critical)	Infra

#	Action	Owner
28	Deception technology (honeytokens, canary files)	SecOps
29	Quarterly external + internal red team exercises	Mgmt
30	Annual third-party compliance audit (PCI-DSS, RBI)	Compliance

Success metrics: Critical MTTR <= 7 days, High MTTR <= 30 days, zero spoofing emails delivered, phishing click-through rate < 5%, 100% MFA adoption on admin accounts.

8. MITRE ATT&CK Coverage (Consolidated)

Tactic	Technique	ID	Finding
Reconnaissance	Active Scanning	T1595	CP1, CP2
Reconnaissance	Gather Victim Host Info	T1592	CP2
Initial Access	Spearphishing Link	T1566.002	NB-19
Execution	Command and Scripting Interpreter	T1059	NB-03
Execution	User Execution	T1204.002	NB-20
Persistence	(lab scope - not exploited)	-	-
Privilege Escalation	Exploitation for Privesc	T1068	NB-08
Defense Evasion	Obfuscated Files or Information	T1027	NB-21
Defense Evasion	Software Packing	T1027.002	NB-22
Credential Access	Input Capture: Web Portal	T1056.003	NB-20
Credential Access	Unsecured Credentials: Files	T1552.001	NB-01
Discovery	File and Directory Discovery	T1083	NB-13
Collection	Data from Information Repositories	T1213	NB-07
Impact	Data Manipulation	T1565	NB-02

9. Evidence Index

All evidence available under **evidence/**: - **C2_imported/** - Infrastructure scan + screenshots - **C3_imported/** - Web + API evidence, PoCs, reports - **gophish/** - Phishing campaign artifacts - **detect_*.txt** - Detection evasion scan results - **payload_*.txt** - Payload metrics - **PHASE*_SUMMARY.txt** - Per-phase summaries

10. Conclusion

The NationalBank Reserve lab environment was fully compromised in under 15 minutes. The kill chain combined human, application, and infrastructure weaknesses, demonstrating the practical reality that security depends on every layer. The 90-day roadmap prioritizes containment (Days 0-7) before hardening (Days 8-30) and maturity (Days 31-90), with measurable success criteria to prevent regression.

Residual risk after roadmap execution: LOW (assuming 80%+ of critical actions completed within their timelines).

Signed: **Mustafa Musa Ahmed**

Date: **2026**

Prepared for authorized lab red team exercise.

End of report.